Studio Nx

Backend(FastAPI/Python) 33 — POST /api/v1/auth/refresh

2026-10-07

Backend(FastAPI/Python) 33 — 라우터 `POST /api/v1/auth/refresh`

항목	내용
파일	`studionx/backend/app/api/v1/auth.py` (함수 이름 `refresh`)
작업	P1-05 로그인 — Access Token 재발급 · PRD 01 FR-105 · FR-108
작성	Claude (AI) · 2026-10-07 · 사용자 검토
이전 · 다음	32 `POST /auth/login` · 34 `POST /auth/logout`

1. 하는 일

브라우저에 남은 **리프레시 쿠키**로 새 Access Token(30분)을 준다. 요청 본문은 없다 — 쿠키가 자동으로 실려 온다.

```
POST /api/v1/auth/refresh
Cookie: snx_refresh=eyJ…

→ 200 {"access_token": "eyJ…(새 30분)", "token_type": "bearer", "expires_in": 1800}
```

쿠키	응답	화면 (`api.js`)
정상 (3일 안, 활동 회원)	200 + 새 Access Token	메모리에 저장, 하던 요청 계속
없음 (로그인 안 한 방문자)	401 "Please sign in."	로그인 안 된 것으로 처리 (정상 흐름)
만료 · 위조 · Access Token · 엉터리	401 "Please sign in again."	로그인 화면으로
진짜지만 회원이 탈퇴 · 정지	401 "Please sign in again."	로그인 화면으로

2. 언제 쓰나

P1-02 의 `refreshAccessToken()` 이 부른다. **이 라우터가 생겨서 P1-02 의 재발급이 실제로 동작한다.**

상황	누가 부르나
페이지를 새로 열었을 때 (메모리 토큰이 비어 있음)	`apiFetch` 가 요청 전에 먼저 (JS 02)
30분이 지나 API 가 401 을 줄 때	`apiFetch` 가 재발급 후 같은 요청을 한 번 다시
헤더 버튼을 그릴 때 · 로그인 전용 페이지를 열 때	`isLoggedIn()` · `requireLogin()` (JS 06 · 07)

ai-note 34(P1-02 · 03 실제 사이트 시험)에서 `/auth/refresh → 500` 이었던 것이 이제 200 · 401 로 바뀐다.

3. 코드

import (파일 맨 위)

```
from typing import Annotated

from fastapi import APIRouter, Cookie, Query, Response, status
from pydantic import EmailStr
```

```
from app.api.deps import Db
from app.core.config import get_settings
from app.core.errors import AppError, ErrorCode
from app.core.security import create_access_token, create_refresh_token, decode_refresh_token
from app.schemas.auth import (…, TokenResponse)
from app.schemas.common import ErrorResponse
from app.services import auth_service
```

`auth.py` 맨 위의 import 이다. **`AppError` · `ErrorCode` · `decode_refresh_token` 을 이번에 추가했다.** 이 함수는 `Annotated` · `Cookie` · `Response` · `Db` · `get_settings` · `AppError` · `ErrorCode` · `create_access_token` · `decode_refresh_token` · `TokenResponse` · `auth_service` 를 쓴다.

함수

```
@router.post(
    "/refresh",
    response_model=TokenResponse,
    responses={401: {"model": ErrorResponse}},
)
def refresh(
    response: Response,
    db: Db,
    refresh_token: Annotated[str | None, Cookie(alias=REFRESH_COOKIE)] = None,
) -> TokenResponse:
    if refresh_token is None:
        raise AppError(ErrorCode.UNAUTHORIZED, 401, "Please sign in.")
    user_id = decode_refresh_token(refresh_token)
    user = auth_service.get_active_user(db, user_id)
    return TokenResponse(
        access_token=create_access_token(user.user_id),
        expires_in=get_settings().jwt_access_minutes * 60,
    )
```

함수 머리는 템플릿에 있었고, 몸통을 채웠다.

문법 풀이

import 문법	뜻
`from fastapi import …, Cookie, …`	요청의 쿠키에서 값을 꺼내는 표시 (템플릿에 이미 있었음)

식	뜻
`Annotated[str | None, Cookie(alias="snx_refresh")]`	쿠키 `snx_refresh` 의 값을 `refresh_token` 인자로 받음. 파이썬 이름과 쿠키 이름이 달라서 `alias` 로 연결
`= None`	쿠키가 없으면 `None` (오류 아님)
`response: Response`	지금은 쓰지 않음 — 나중에 리프레시 토큰을 갈아 끼울 때(아래 §5) 쿠키를 심는 데 씀

4. 흐름

1. 쿠키가 없으면 401 "Please sign in."
2. 28 로 토큰 검사 → 회원 번호 (실패하면 401 "Please sign in again.")

3. 30 으로 회원이 아직 활동 중인지 (아니면 401)
4. 26 으로 새 Access Token → 200

5. 왜 이렇게

선택	이유
쿠키 없음과 토큰 이상을 다른 문구로	쿠키가 없는 것은 "처음부터 로그인 안 함" — 정상이다. 쿠키가 있는데 안 되는 것은 "로그인이 풀림". 코드는 둘 다 `UNAUTHORIZED` 라 `api.js` 처리는 같다 (06 과 같은 나눔)
토큰 검사(28) 다음에 회원 확인(30)	토큰은 진짜여도 그 사이 탈퇴 · 정지했을 수 있다 (30 §2)
리프레시 토큰을 갈아 끼우지 않음 (템플릿의 선택 사항)	갈아 끼우면 재발급할 때마다 3일이 다시 늘어나 사실상 영원히 로그인된다. 또 체크 여부(`remember`)를 토큰에 따로 담아야 한다. 지금은 **로그인 후 3일이면 다시 로그인**으로 단순하게 둔다
실패해도 쿠키를 지우지 않음	오류 응답은 01 처리기가 새로 만들어서, 여기서 붙인 쿠키가 실리지 않는다. 쿠키는 3일이 지나면 브라우저가 지우고, 로그아웃(34)이 지운다

6. 시험 (`tests/test_auth_routes.py` 에 6개 추가 · 모두 40개, 실제 앱 + MySQL)

시험 도구(`TestClient`)는 브라우저처럼 로그인 응답의 쿠키를 기억했다가 다음 요청에 실어 보낸다.

시험	확인한 것
로그인 후 재발급 (체크 · 안 체크)	200, `bearer` · 1800, 새 토큰을 05 로 읽으면 그 회원 번호
쿠키 없음	401 "Please sign in."
엉터리 쿠키 · Access Token 을 쿠키에	401 `UNAUTHORIZED` "Please sign in again."
로그인 뒤 탈퇴	쿠키는 남아 있어도 401 (30 이 막음)

전체 시험 231개 통과, `ruff` 검사 통과. 시험 뒤 남은 행 0개.